

وثيقة استراتيجية

الأمن السيبراني

منظمي

نوع الوثيقة

وثيقة استراتيجية

القطاع

حكومي

التصنيف

سري

الإصدار

1.0

الحالة

مسودة

تاريخ الإعداد

18 June 2026

بطاقة ضبط الوثيقة

المنظمة	
منظمتي	
القطاع	
حكومي	
المجال	
الأمن السيبراني	
نوع الوثيقة	
وثيقة استراتيجية	
التصنيف	
سري	
الإصدار	
1.0	
الحالة	
مسودة	
تاريخ الإعداد	
18 June 2026	
أعد بواسطة	
Mizan GRC Platform	

المحتويات

1	الملخص التنفيذي
2	النطاق والأطر المرجعية المعتمدة
3	المنهجية
4	ملخص الوضع الراهن ومستوى النضج
5	الرؤية والأهداف الاستراتيجية
6	الركائز الاستراتيجية
7	البيئة التنظيمية والتحديات
8	تحليل الفجوات
9	خارطة الطريق التنفيذية
10	مؤشرات الأداء الرئيسية
11	تقييم الثقة والمخاطر
12	نموذج الحوكمة والمسؤوليات
13	مصفوفة تتبع الأطر المرجعية
14	الملاحق

هذه الوثيقة سرية ومعدة حصراً للاستخدام الداخلي. جميع التوصيات مبنية على بيانات التشخيص المقدمة.

الملخص التنفيذي

الغرض	الأمن السيبراني المعدة لمنظمتي (القطاع: حكومي)، مبنية على تحليل تشخيصي كامل ومواءمة مع 2 من الأطر المرجعية تقدم هذه الوثيقة استراتيجية المختارة ((NCA ECC, NCA DCC (NCA ECC (Essential Cybersecurity Controls), NCA DCC (Data Cybersecurity Controls)).
الأطر المرجعية	NCA ECC (Essential Cybersecurity Controls) — NCA DCC (Data Cybersecurity Controls)
أبرز الأولويات	وتعيين CISO؛ بناء برنامج استخبارات التهديدات وربطه بمنظومة الرصد في SOC؛ تطبيق IAM/PAM/MFA؛ تأسيس تأسيس إدارة الأمن السيبراني NCA ECC-5 وخطط الاستجابة؛ تنفيذ برنامج اختبار الاختراق الدوري وتقييمات الثغرات الأمنية وفق CSIRT
أبرز الفجوات	السيبراني / CISO؛ غياب مركز العمليات الأمنية SIEM / SOC؛ ضعف إدارة الهوية والوصول IAM / PAM / MFA؛ غياب هيكل حوكمة الأمن غياب فريق الاستجابة للحوادث CSIRT وخطة موثقة؛ قصور إدارة الثغرات الأمنية ومنع فقدان البيانات DLP
أفق التنفيذ	24 شهر
درجة الثقة	78%
المخاطر الرئيسية	في الأنظمة الحيوية غير المرقعة؛ هجمات التصيد الاحتيالي المستهدفة على الحسابات ذات الصلاحيات العليا؛ هجمات استغلال الثغرات الصفرية ضعف التجزئة الشبكية؛ اختراق البيانات عبر طرف ثالث لا يمثل لاشتراطات NCA DCC؛ انعدام الكشف المبكر عن برمجيات الفدية الناتجة عن الحوادث بسبب غياب سجلات SIEM موحدة

النطاق والأطر المرجعية المعتمدة

NCA ECC (Essential Cybersecurity Controls) (ECC)

يعكس هذا الإطار في الاستراتيجية عبر مجالات: الحوكمة، إدارة الهوية، مركز العمليات الأمنية، الاستجابة للحوادث، إدارة الثغرات.

NCA DCC (Data Cybersecurity Controls) (DCC)

يعكس هذا الإطار في الاستراتيجية عبر مجالات: تصنيف البيانات، التشفير، DLP، البيانات الحساسة، حماية البيانات.

المنهجية

المرحلة 1 – تحليل المدخلات التشخيصية

مراجعة منهجية للبيانات التشخيصية المدخلة من المنظمة (القطاع، الحجم، النضج الحالي، الأنظمة، التحديات) وتأكيد جودة المدخلات قبل بدء أي تحليل.

المرحلة 2 – تحديد نطاق الأطر المرجعية

اعتماد الأطر التالية كنطاق رسمي للتحليل والمواءمة: NCA ECC (Essential Cybersecurity Controls), NCA DCC (Data Cybersecurity Controls), NCA ECC, NCA DCC.

المرحلة 3 – تحليل تغطية القدرات

مطابقة المدخلات والضوابط القائمة مع عائلات القدرات التي تتطلبها الأطر المختارة (الحوكمة، إدارة الهوية، المراقبة، الاستجابة، الوصول عن بعد، حماية البيانات...).

المرحلة 4 – تحليل الفجوات وترتيب الأولويات

استخراج الفجوات بين الوضع الحالي ومتطلبات الأطر، وترتيبها وفق الأثر والأولوية والقابلية للمعالجة.

المرحلة 5 – تصميم خارطة الطريق والمؤشرات

بناء خارطة طريق متعددة الموجات (قصيرة/متوسطة/طويلة المدى) مرتبطة بمؤشرات أداء (KPI) ومؤشرات مخاطر (KRI) قابلة للقياس.

المرحلة 6 – تقييم المخاطر والثقة

تقدير المخاطر التنفيذية ومخاطر التغيير، وحساب درجة ثقة شاملة في قابلية تنفيذ الاستراتيجية.

المرحلة 7 – التحقق وبوابات الجودة

اجتياز سلسلة بوابات التحقق: التحقق من المجال، كثافة المحتوى، تغطية الأطر، التدقيق الدلالي، ثم التدقيق النهائي قبل النشر.

ملخص الوضع الراهن ومستوى النضج

السياق التنظيمي: يفرض الإطار التنظيمي المطبق على منظمتي — وعلى رأسه متطلبات NCA ECC, NCA DCC المعمول بها في قطاع حكومي — التزامات محددة على حوكمة الأمن السيبراني، بما يشمل إثبات تطبيق الضوابط والحوكمة المستمرة وإعداد أدلة التدقيق وفق اللوائح والأنظمة السارية. وتشمل الأطر التنظيمية المختارة الملزمة لمنظمتي: NCA ECC، NCA DCC. إذ تكشف القدرات الأساسية عن فجوات يجب سدها قبل تحقيق أي التزام مستدام.

سياق التهديدات: تشير البيانات العامة لفرق الاستجابة الوطنية خلال آخر دورة تقرير إلى ارتفاع ملحوظ في حوادث اختراق سلاسل الإمداد، والتصيد الموجه، وحملات برامج الفدية — مما يرفع أولوية تحصين ضوابط الأمن السيبراني لدى منظمتي وتسريع النضج التشغيلي في الاستجابة للحوادث.

الرؤية والأهداف الاستراتيجية

إنشاء إدارة متخصصة للأمن السيبراني وتعيين CISO وتفعيل لجنة الحوكمة ونموذج التشغيل 1.

المستهدف القابل للقياس	إنجاز الهيكل التنظيمي بنسبة 100% وتعيين CISO مؤهل خلال الإطار المحدد
المبرر	ضرورة وجود هيكل تنظيمي متخصص لقيادة وإدارة برنامج الأمن السيبراني بفعالية
الإطار الزمني	6 أشهر

نشر برنامج إدارة الثغرات الأمنية عبر جميع الأصول الحرجة 2.

المستهدف القابل للقياس	معالجة 95% من الثغرات الحرجة خلال 72 ساعة من اكتشافها
المبرر	ضعف دورة اكتشاف الثغرات وغياب آلية تتبع منهجية
الإطار الزمني	9 أشهر

إنشاء وتشغيل مركز عمليات الأمن السيبراني SOC/SIEM 3.

المستهدف القابل للقياس	تشغيل مراقبة أمنية مستمرة 24/7 وتغطية 90% من الأنظمة الحرجة خلال 12 شهرا
المبرر	معالجة فجوة الرصد المستمر وتحسين القدرة على الكشف المبكر والاستجابة للتهديدات
الإطار الزمني	12 شهرا

نشر برنامج التوعية بالأمن السيبراني لجميع الموظفين وفق متطلبات NCA DCC 4.

المستهدف القابل للقياس	خفض معدل النقر في اختبارات التصيد الاحتيالي إلى أقل من 90%
المبرر	ارتفاع معدل نجاح هجمات الهندسة الاجتماعية الناجمة عن ضعف الوعي
الإطار الزمني	6 أشهر

تنفيذ منهجية تصنيف البيانات وفق إطار NCA DCC عبر جميع الأنظمة 5.

المستهدف القابل للقياس	تصنيف 100% من الأصول المعلوماتية الحرجة ضمن مخطط تصنيف موثق
المبرر	غياب سياسة تصنيف تحدد مستويات الحماية المناسبة لكل فئة بيانات
الإطار الزمني	9 أشهر

تعزيز إدارة الهوية والوصول والصلاحيات المميزة 6.

المستهدف القابل للقياس	تغطية 95% من الأنظمة الحرجة بضوابط IAM/PAM/MFA خلال 12 شهرا
المبرر	تقليل مخاطر الوصول غير المصرح به
الإطار الزمني	12 شهرا

بناء قدرات الاستجابة للحوادث عبر CSIRT 7.

المستهدف القابل للقياس	تشغيل CSIRT مع SLA للاستجابة للحوادث الحرجة
المبرر	احتواء الحوادث وتقليل الأثر التشغيلي
الإطار الزمني	12 شهر

تعزيز حماية البيانات عبر التصنيف والتشفير و DLP 8.

المستهدف القابل للقياس	حماية 95% من البيانات الحساسة المصنفة
المبرر	تلبية متطلبات NCA DCC لحماية البيانات
الإطار الزمني	18 شهر

الركائز الاستراتيجية

2. الركائز الاستراتيجية

حوكمة ونموذج التشغيل

تعزز هذه الركيزة المساءلة المؤسسية على الأمن السيبراني عبر هياكل حوكمة واضحة ولجان فعالة، تشمل المبادرات اعتماد وتحديث سياسات الحوكمة السيبرانية وفق NCA ECC وتوزيع الأدوار وربط القرارات التنفيذية بمتطلبات NCA ECC.

اعتماد وتحديث سياسات الحوكمة السيبرانية وفق NCA ECC. سياسات الحوكمة السيبرانية

الوصف	منصة حوكمة سيبرانية معتمدة مع مكتبة سياسات وسجلات اعتماد محدثة
-------	--

ميثاق لجنة حوكمة أمن سيبراني معتمد مع اجتماعات ربع سنوية. لجنة حوكمة الأمن

الوصف	لجنة حوكمة أمن سيبراني فعالة بميثاق ومحاضر اجتماعات ربع سنوية
-------	---

توزيع مسؤوليات RACI للأمن السيبراني عبر الإدارات. مصفوفة RACI

الوصف	مصفوفة RACI معتمدة لأدوار الأمن السيبراني والامتثال
-------	---

الحماية والكشف والاستجابة

تركز هذه الركيزة على القدرات التشغيلية للكشف والاستجابة للتهديدات، تشمل تشغيل SOC/SIEM وفريق CSIRT وتحسين الرصد المستمر للأصول الحرجة.

تشغيل مركز عمليات الأمن مع قواعد SIEM للأصول الحرجة. تشغيل SOC/SIEM

الوصف	مركز SOC تشغيلي 24/7 مع قواعد SIEM للأصول الحرجة
-------	--

تأسيس فريق الاستجابة للحوادث وخطط الاستجابة المعتمدة. فريق CSIRT

الوصف	فريق CSIRT جاهز مع خطط استجابة وتمارين محاكاة سنوية
-------	---

تنفيذ برنامج الرصد والمراقبة وفق خطة زمنية معتمدة. الرصد والمراقبة

الوصف	تغطية SIEM لـ 90% من الأصول الحرجة مع لوحات مراقبة
-------	--

الهوية وحماية البيانات

تغطي هذه الركيزة ضوابط الهوية وحماية البيانات وفق NCA DCC. تشمل IAM/PAM/MFA وتصنيف البيانات وتفعيل DLP للبيانات الحساسة.

تنفيذ برنامج IAM/PAM/MFA وفق خطة زمنية معتمدة. IAM/PAM/MFA

الوصف	تغطية MFA لجميع الحسابات الحرجة والامتيازات
-------	---

تنفيذ برنامج تصنيف البيانات وفق خطة زمنية معتمدة. تصنيف البيانات

الوصف	سجل بيانات مصنفة معتمد مع جرد للبيانات الحساسة
-------	--

تفعيل منصة DLP ومراقبة تسرب البيانات الحساسة. DLP

الوصف	منصة DLP مفعلة مع قواعد مراقبة تسرب للبيانات الحساسة
-------	--

المرونة واستمرارية الأعمال

تضمن هذه الركيزة استمرارية العمليات عبر النسخ الاحتياطي والتعافي من الكوارث وخطط استمرارية الأعمال المختبرة دورياً.

تنفيذ برنامج النسخ الاحتياطي وفق خطة زمنية معتمدة. النسخ الاحتياطي

الوصف	خطة نسخ احتياطي معتمدة مع اختبارات استعادة ناجحة
-------	--

تنفيذ برنامج التعافي من الكوارث وفق خطة زمنية معتمدة. التعافي من الكوارث

الوصف	خطة تعافي من الكوارث مختبرة مع RTO/RPO معتمدة
-------	---

تنفيذ برنامج استمرارية الأعمال وفق خطة زمنية معتمدة. استمرارية الأعمال

الوصف	خطط استمرارية أعمال معتمدة للعمليات الحرجة
-------	--

البيئة التنظيمية والتهديدات

السياق التنظيمي: يفرض الإطار التنظيمي المطبق على منظمتي — وعلى رأسه متطلبات NCA ECC, NCA DCC المعمول بها في قطاع حكومي — التزامات محددة على حوكمة الأمن السيبراني، بما يشمل إثبات تطبيق الضوابط والحوكمة المستمرة وإعداد أدلة التدقيق وفق اللوائح والأنظمة السارية. وتشمل الأطر التنظيمية المختارة الملزمة لمنظمتي: NCA ECC، NCA DCC. إذ تكشف القدرات الأساسية عن فجوات يجب سدها قبل تحقيق أي التزام مستدام.

سياق التهديدات: تشير البيانات العامة لفرق الاستجابة الوطنية خلال آخر دورة تقرير إلى ارتفاع ملحوظ في حوادث اختراق سلاسل الإمداد، والتصيد الموجه، وحملات برامج الفدية — مما يرفع أولوية تحصين ضوابط الأمن السيبراني لدى منظمتي وتسريع النضج التشغيلي في الاستجابة للحوادث.

السياق التشغيلي وسياق الأعمال: يترتب على منظمتي موازنة متطلبات التحول الرقمي مع الحفاظ على استمرارية الأعمال والعمليات في قطاع حكومي، وضمان أن تواكب استثمارات الأمن السيبراني وتيرة توسع الخدمات والعمليات دون إحداث فجوات تدقيقية أو ضغط تشغيلي على الكوادر.

تطبيق الضوابط المرتبطة ومتابعتها	عالية	عال	تنظيمي	
تطبيق الضوابط المرتبطة ومتابعتها	عالية	عال	تهديد	
تطبيق الضوابط المرتبطة ومتابعتها	متوسطة	متوسط	أعمال	

تحليل الفجوات

1	حوكمة الأمن السيبراني / CISO غياب هيكل	ل CISO أو إطار تنظيمي معتمدا يحدد مسؤوليات الأمن السي... لا تمتلك المنظمة دورا رسميا	حرجة	مفتوحة
2	العمليات الأمنية SIEM / SOC غياب مركز	أو منصة SIEM لرصد التهديدات وتحليلها في الوقت الفعلي، مما... لا يوجد مركز عمليات أمنية فعال	حرجة	مفتوحة
3	والوصول IAM / PAM / MFA ضعف إدارة الهوية	وإدارة الحسابات المميزة PAM، وعدم تطبيق مبدأ الحد الأدنى... غياب ضوابط المصادقة متعددة العوامل	عالية	مفتوحة
4	للحوادث CSIRT وخطة موثقة غياب فريق الاستجابة	للاستجابة للحوادث السيبرانية ولا فريق CSIRT مشكل رسميا، مم... لا تملك المنظمة خطة معتمدة	عالية	مفتوحة
5	الأمنية ومنع فقدان البيانات DLP قصور إدارة الثغرات	الأمنية وأدوات منع فقدان البيانات DLP وضوابط الوصول عن ب... غياب برنامج دوري لإدارة الثغرات	عالية	مفتوحة

1

الإجراء	إصدار قرار تنظيمي رسمي بتعيين CISO وتحديد صلاحياته وتبعية التنظيمية المباشرة للإدارة العليا
المسؤول	الإدارة العليا
الإطار الزمني	الشهر 1
النتائج	قرار تعيين رسمي موثق

2

الإجراء	تشكيل لجنة حوكمة الأمن السيبراني بمشاركة أصحاب المصلحة الرئيسيين وتحديد دورية اجتماعاتها
المسؤول	CISO
الإطار الزمني	الشهر 1-2
النتائج	ميثاق لجنة الحوكمة معتمد

3

الإجراء	إعداد السياسة الرئيسية للأمن السيبراني ومنظومة السياسات الفرعية وفق متطلبات NCA ECC ورفعها للاعتماد
المسؤول	المسؤول أمن السيبراني Lead e
الإطار الزمني	الشهر 2-4
النتائج	حزمة سياسات الأمن السيبراني معتمدة

4

الإجراء	تحديد مؤشرات الأداء الرئيسية KPIs وآلية رفع تقارير الأمن السيبراني دوريا للإدارة العليا
المسؤول	CISO
الإطار الزمني	الشهر 3-4
النتائج	لوحة متابعة حوكمة الأمن السيبراني فعالة

5

الإجراء	إجراء تقييم النضج الأولي وفق NCA ECC وتوثيق خارطة الطريق التصحيحية
---------	--

المسؤول	المسؤول أمن السيراني e Lead
الإطار الزمني	الشهر 4-5
الناتج	تقرير تقييم النضج وخارطة الطريق المعتمدة

1

الإجراء	تحديد نموذج تشغيل SOC ال مناسب (داخلي، مدار، هجين) بناء على حجم المنظمة ومتطلبات NCA ECC
المسؤول	CISO
الإطار الزمني	الشهر 1-2
الناتج	دراسة جدوى نموذج SOC معتمدة

2

الإجراء	تصميم هيكل SOC وتحديد الأدوار الوظيفية (محللو Tier 1/2/3) ومتطلبات التوظيف
المسؤول	SOC Manager
الإطار الزمني	الشهر 2-3
الناتج	هيكل تنظيمي SOC وأوصاف وظيفية

3

الإجراء	تحديد متطلبات منصة SIEM وإصدار وثيقة المتطلبات الفنية وإطلاق عملية الاستشارة والاستحواذ
المسؤول	SOC Manager
الإطار الزمني	الشهر 2-4
الناتج	وثيقة متطلبات SIEM وعقد التوريد

4

الإجراء	تنفيذ تكاملات مصادر السجلات الرئيسية (جدران الحماية، نقاط النهاية، Active Directory) مع منصة SIEM
المسؤول	SOC Manager
الإطار الزمني	الشهر 4-6
الناتج	تكاملات SIEM فعالة مع تغطية 80% من المصادر الحرجة

5

الإجراء	قواعد الكشف وسيناريوهات الاستجابة (Playbooks) استنادا إلى إطار MITRE ATT&CK وبيئة القطاع الحكومي بناء مكتبة
المسؤول	SOC Manager
الإطار الزمني	الشهر 5-7
الناتج	مكتبة قواعد كشف ومجموعة Playbooks تشغيلية

1

الإجراء	إجراء جرد شامل لجميع الحسابات (عادية، مميزة، خدمية) وتوثيق حالة المصادقة الحالية
المسؤول	المسؤول أمن السيراني e Lead
الإطار الزمني	الشهر 1
الناتج	سجل حسابات موثق وتقرير فجوات MFA

2

الإجراء	نشر حل إدارة الهوية وتطبيق المصادقة متعددة العوامل MFA على جميع الأنظمة والتطبيقات الحرجة
المسؤول	CISO
الإطار الزمني	الشهر 2-4
النتائج	تغطية 95% MFA على الأنظمة الحرجة
3	
الإجراء	تنفيذ حل إدارة الحسابات المميزة PAM مع تفعيل تسجيل جلسات الوصول المميز ومراجعتها دوريا
المسؤول	SOC Manager
الإطار الزمني	الشهر 3-5
النتائج	منصة PAM فعالة مع تسجيل كامل للجلسات المميزة
4	
الإجراء	تطبيق مبدأ الحد الأدنى من الصلاحيات ومراجعة دورية لصلاحيات الوصول كل 90 يوما وفق NCA ECC
المسؤول	المسؤول أمن السيرياني e Lead
الإطار الزمني	الشهر 4-6
النتائج	تقارير مراجعة صلاحيات دورية موثقة
5	
الإجراء	وضع سياسة إدارة دورة حياة الهوية (الإنشاء، التعديل، الإلغاء) وربطها بإجراءات الموارد البشرية
المسؤول	المسؤول أمن السيرياني e Lead
الإطار الزمني	الشهر 5-6
النتائج	سياسة دورة حياة الهوية معتمدة ومطبقة
1	
الإجراء	تشكيل فريق CSIRT رسميا بتحديد الأدوار والمسؤوليات وقنوات التواصل الطارئة وآليات التصعيد
المسؤول	CISO
الإطار الزمني	الشهر 1-2
النتائج	ميثاق CSISO وهيكل الفريق معتمد
2	
الإجراء	الاستجابة للحوادث السيريانية (IRP) مشتملة على مراحل الكشف والاحتواء والاستئصال والتعافي وفق NCA ECC صياغة خطة
المسؤول	المسؤول أمن السيرياني e Lead
الإطار الزمني	الشهر 2-3
النتائج	خطة استجابة للحوادث معتمدة
3	
الإجراء	بناء Playbooks تفصيلية للسيناريوهات الحرجة (برمجيات الفدية، التصيد الاحتيالي، الثغرات الصفرية)
المسؤول	SOC Manager
الإطار الزمني	الشهر 3-4
النتائج	مجموعة Playbooks جاهزة للتشغيل

4

الإجراء	تنفيذ تمرين محاكاة (Tabletop Exercise) شامل يغطي سيناريو اختراق حرج مع توثيق الدروس المستفادة
المسؤول	CISO
الإطار الزمني	الشهر 4-5
النتائج	تقرير تمرين المحاكاة وخطة التحسين

5

الإجراء	إرساء آلية التنسيق مع CERT الوطني وإجراءات الإبلاغ الإلزامي عن الحوادث وفق متطلبات NCA ECC
المسؤول	المسؤول أمن السيراني e Lead
الإطار الزمني	الشهر 5-6
النتائج	بروتوكول تنسيق وإبلاغ موثق ومعتمد

1

الإجراء	بناء سجل أصول تقني شامل يصنف الأنظمة والتطبيقات وفق درجة الحساسية والأثر التشغيلي
المسؤول	المسؤول أمن السيراني e Lead
الإطار الزمني	الشهر 1-2
النتائج	سجل أصول تقني موثق ومصنف

2

الإجراء	تنفيذ برنامج فحص الثغرات الأمنية الدوري (أسبوعي للبنية الحرجة، شهري للأنظمة العامة) وإعداد تقارير المعالجة
المسؤول	SOC Manager
الإطار الزمني	الشهر 2-3
النتائج	تقارير فحص الثغرات الأمنية الدورية وسجل المعالجة

3

الإجراء	إطلاق برنامج اختبار الاختراق السنوي لتقييم مستوى المقاومة الفعلي للبنية التحتية الحرجة
المسؤول	CISO
الإطار الزمني	الشهر 3-5
النتائج	تقرير اختبار الاختراق وخطة معالجة المخرجات

4

الإجراء	نشر حلول لمنع فقدان البيانات DLP على نقاط النهاية والبريد الإلكتروني وبوابات الويب وفق متطلبات NCA DCC
المسؤول	SOC Manager
الإطار الزمني	الشهر 4-6
النتائج	منصة DLP فعالة مع سياسات تصنيف البيانات مطبقة

5

الإجراء	الوصول عن بعد الآمن (VPN معتمد، تحقق متعدد العوامل، تسجيل الجلسات) وفق NCA ECC و NCA DCC
المسؤول	المسؤول أمن السيراني e Lead
الإطار الزمني	الشهر 5-7

بنية وصول عن بعد آمنة موثقة ومختبرة	النتائج
-------------------------------------	---------

خارطة الطريق التنفيذية

تأسيس إدارة الأمن السيبراني وتعيين CISO .المرحلة 1: تأسيس (1-6 أشهر)
المرحلة 1: تأسيس (1-6 أشهر) :المرحلة

1-6 أشهر: الفترة

تأسيس إدارة الأمن السيبراني وتعيين CISO :المبادرة
الإدارة العليا / CISO :المسؤول

هيكل CISO ولجنة حوكمة معتمدة :المخرج المتوقع
الإطار المرتبط :NCA ECC

تصنيف وجرد البيانات الحساسة .المرحلة 1: تأسيس (1-6 أشهر)
المرحلة 1: تأسيس (1-6 أشهر) :المرحلة

1-6 أشهر: الفترة

تصنيف وجرد البيانات الحساسة :المبادرة

مدير حماية البيانات :المسؤول

سجل بيانات مصنفة ومعتمد :المخرج المتوقع
الإطار المرتبط :NCA DCC

تفعيل لجنة حوكمة الأمن السيبراني .المرحلة 1: تأسيس (1-6 أشهر)
المرحلة 1: تأسيس (1-6 أشهر) :المرحلة

1-6 أشهر: الفترة

تفعيل لجنة حوكمة الأمن السيبراني :المبادرة

الإدارة العليا / CISO :المسؤول

ميثاق لجنة حوكمة ومصفوفة RACI معتمدة :المخرج المتوقع
الإطار المرتبط :NCA ECC

بناء برنامج استخبارات التهديدات وربطه بمنظومة الرصد في SOC .المرحلة 2: تمكين وتشغيل (7-18 شهر)
المرحلة 2: تمكين وتشغيل (7-18 شهر) :المرحلة

9-15 شهر: الفترة

بناء برنامج استخبارات التهديدات وربطه بمنظومة الرصد في SOC :المبادرة
مدير SOC :المسؤول

مركز SOC تشغيلي مع تغطية SIEM :المخرج المتوقع
الإطار المرتبط :NCA ECC

تطبيق IAM/PAM/MFA .المرحلة 2: تمكين وتشغيل (7-18 شهر)
المرحلة 2: تمكين وتشغيل (7-18 شهر) :المرحلة

7-18 شهر: الفترة

تطبيق IAM/PAM/MFA :المبادرة

مدير IAM/PAM :المسؤول

منصة IAM/PAM مع MFA للحسابات الحرجة :المخرج المتوقع
الإطار المرتبط :NCA ECC

تأسيس CSIRT وخطط الاستجابة .المرحلة 2: تمكين وتشغيل (7-18 شهر)
المرحلة 2: تمكين وتشغيل (7-18 شهر) :المرحلة

7-18 شهر: الفترة

تأسيس CSIRT وخطط الاستجابة :المبادرة

قائد CSIRT: المسؤول

فريق CSIRT وخطط استجابة معتمدة ومختبرة: المخرج المتوقع

NCA ECC: الإطار المرتبط

ضبط معالجة البيانات الحساسة: المرحلة 3: تحسين واستدامة (19-24 شهر)

المرحلة 3: تحسين واستدامة (19-24 شهر): المرحلة

19-24 شهر: الفترة

ضبط معالجة البيانات الحساسة: المبادرة

مسؤول حماية البيانات: المسؤول

إجراءات معالجة بيانات حساسة معتمدة: المخرج المتوقع

NCA DCC: الإطار المرتبط

تفعيل DLP ومراقبة تسرب البيانات: المرحلة 2: تمكين وتشغيل

المرحلة 2: تمكين وتشغيل: المرحلة

7-18 شهر: الفترة

تفعيل DLP ومراقبة تسرب البيانات: المبادرة

مدير حماية البيانات: المسؤول

منصة DLP وقواعد مراقبة تسرب البيانات مفعلة: المخرج المتوقع

NCA DCC: الإطار المرتبط

تطبيق ضوابط التشفير وإدارة المفاتيح: المرحلة 2: تمكين وتشغيل

المرحلة 2: تمكين وتشغيل: المرحلة

7-18 شهر: الفترة

تطبيق ضوابط التشفير وإدارة المفاتيح: المبادرة

مدير حماية البيانات: المسؤول

ضوابط تشفير وإدارة مفاتيح مطابقة: المخرج المتوقع

NCA DCC: الإطار المرتبط

مؤشرات الأداء الرئيسية

متوسط زمن اكتشاف الحوادث الأمنية

متوسط زمن اكتشاف الحوادث الأمنية: المؤشر

النوع: KPI

> 4 ساعات: القيمة المستهدفة

المالك: CISO

نسبة معالجة الحوادث الحرجة ضمن SLA

نسبة معالجة الحوادث الحرجة ضمن SLA: المؤشر

النوع: KPI

95%: القيمة المستهدفة

المالك: CISO

معدل تغطية المصادقة متعددة العوامل (MFA) على الحسابات المميزة (PAM)

معدل تغطية المصادقة متعددة العوامل (MFA) على الحسابات المميزة (PAM): المؤشر

النوع: KPI

100% للحسابات المميزة أو 95% للمستخدمين: القيمة المستهدفة

المالك: CISO

متوسط زمن اكتشاف الحوادث الأمنية

متوسط زمن اكتشاف الحوادث الأمنية: المؤشر

النوع: KPI

15 دقيقة: القيمة المستهدفة

المالك: CISO

متوسط زمن الاستجابة للحوادث (MTTR)

متوسط زمن الاستجابة للحوادث (MTTR): المؤشر

النوع: KPI

4 ساعات: القيمة المستهدفة

المالك: CISO

نسبة الثغرات الأمنية الحرجة المعالجة ضمن إطار التصحيح المحدد

نسبة الثغرات الأمنية الحرجة المعالجة ضمن إطار التصحيح المحدد: المؤشر

النوع: KPI

95% خلال 72 ساعة: القيمة المستهدفة

المالك: CISO

معدل فشل اختبارات التصيد الاحتيالي

معدل فشل اختبارات التصيد الاحتيالي: المؤشر

النوع: KRI

أقل من 5%: القيمة المستهدفة

CISO: المالك

معدل نجاح اختبارات التعافي من الكوارث واستعادة النسخ الاحتياطي

معدل نجاح اختبارات التعافي من الكوارث واستعادة النسخ الاحتياطي: المؤشر

KPI: النوع

99%: القيمة المستهدفة

CISO: المالك

نسبة تغطية تصنيف البيانات الحساسة

نسبة تغطية تصنيف البيانات الحساسة: المؤشر

KRI: النوع

95% أو 100% للبيانات الحساسة المصنفة: القيمة المستهدفة

CISO: المالك

نسبة تغطية تشفير البيانات الحساسة

نسبة تغطية تشفير البيانات الحساسة: المؤشر

KPI: النوع

95% أو 100% للبيانات الحساسة المصنفة: القيمة المستهدفة

CISO: المالك

نسبة تغطية DLP للبيانات الحساسة

نسبة تغطية DLP للبيانات الحساسة: المؤشر

KPI: النوع

95% أو 100% للبيانات الحساسة المصنفة: القيمة المستهدفة

CISO: المالك

متوسط زمن اكتشاف الحوادث الأمنية

متوسط زمن اكتشاف الحوادث الأمنية: المؤشر

مجموع أزمنة اكتشاف الحوادث / عدد الحوادث: الصيغة

SIEM / SOC: مصدر البيانات

نسبة معالجة الحوادث الحرجة ضمن SLA

نسبة معالجة الحوادث الحرجة ضمن SLA: المؤشر

(عدد الحوادث المعالجة ضمن SLA ÷ إجمالي الحوادث) × 100: الصيغة

ITSM / SOAR / SIEM: مصدر البيانات

معدل تغطية المصادقة متعددة العوامل (MFA) على الحسابات المميزة (PAM)

معدل تغطية المصادقة متعددة العوامل (MFA) على الحسابات المميزة (PAM): المؤشر

(عدد الحسابات أو الأنظمة المغطاة بضوابط IAM/PAM ÷ إجمالي الحسابات أو الأنظمة المستهدفة) × 100: الصيغة

IAM / PAM: مصدر البيانات

متوسط زمن اكتشاف الحوادث الأمنية

متوسط زمن اكتشاف الحوادث الأمنية: المؤشر
مجموع أزمنة اكتشاف الحوادث / عدد الحوادث: الصيغة
SIEM / SOC: مصدر البيانات

متوسط زمن الاستجابة للحوادث (MTTR)
متوسط زمن الاستجابة للحوادث (MTTR): المؤشر
مجموع أزمنة الاستجابة للحوادث الحرجة / عدد الحوادث الحرجة: الصيغة
ITSM / SOAR / SIEM: مصدر البيانات

نسبة الثغرات الأمنية الحرجة المعالجة ضمن إطار التصحيح المحدد
نسبة الثغرات الأمنية الحرجة المعالجة ضمن إطار التصحيح المحدد: المؤشر
(عدد الثغرات الحرجة المغلقة ضمن SLA ÷ إجمالي الثغرات الحرجة) × 100: الصيغة
منصة إدارة الثغرات: مصدر البيانات

معدل فشل اختبارات التصيد الاحتيالي
معدل فشل اختبارات التصيد الاحتيالي: المؤشر
(عدد الموظفين الذين فشلوا في اختبار التصيد ÷ إجمالي الموظفين المختبرين) × 100: الصيغة
منصة محاكاة التصيد: مصدر البيانات

معدل نجاح اختبارات التعافي من الكوارث واستعادة النسخ الاحتياطي
معدل نجاح اختبارات التعافي من الكوارث واستعادة النسخ الاحتياطي: المؤشر
(عدد عمليات النسخ الناجحة ÷ إجمالي عمليات النسخ) × 100: الصيغة
منصة النسخ الاحتياطي: مصدر البيانات

نسبة تغطية تصنيف البيانات الحساسة
نسبة تغطية تصنيف البيانات الحساسة: المؤشر
بيانات مصنفة / إجمالي البيانات الحساسة × 100: الصيغة
سجل التصنيف: مصدر البيانات

نسبة تغطية تشفير البيانات الحساسة
نسبة تغطية تشفير البيانات الحساسة: المؤشر
(عدد الأصول أو البيانات الحساسة المحمية بالتشفير و DLP ÷ إجمالي الأصول أو البيانات الحساسة المستهدفة) × 100: الصيغة
منصة التشفير / DLP / منصة تصنيف البيانات: مصدر البيانات

نسبة تغطية DLP للبيانات الحساسة
نسبة تغطية DLP للبيانات الحساسة: المؤشر
(عدد الأصول أو البيانات الحساسة المحمية بالتشفير و DLP ÷ إجمالي الأصول أو البيانات الحساسة المستهدفة) × 100: الصيغة
منصة التشفير / DLP / منصة تصنيف البيانات: مصدر البيانات

تقييم الثقة والمخاطر

درجة الثقة: 78%

مستوى النضج الأولي (Initial) يعكس غياب السياسات الموثقة وضعف التكامل بين متطلبات NCA ECC و NCA DCC على مستوى الحوكمة والعمليات التشغيلية، مما يقيد قدرة المنظمة على الاستجابة للحوادث وإدارة الثغرات الأمنية بصورة منهجية. الفجوات الجوهرية تشمل انعدام هيكل واضح لفريق الاستجابة للحوادث، وقصور في آليات التحكم في الوصول وإدارة الهوية، وضعف رؤية SOC عبر الأصول الحيوية لل منظمة.

اكتمال المدخلات

20% الوزن

4: الدرجة

15.6% المساهمة

تغطية الأطر المرجعية

20% الوزن

4: الدرجة

15.6% المساهمة

جدوى خارطة الطريق

20% الوزن

4: الدرجة

15.6% المساهمة

جاهزية الموارد

15% الوزن

4: الدرجة

11.7% المساهمة

نضج الحوكمة

15% الوزن

4: الدرجة

11.7% المساهمة

جاهزية حماية البيانات

10% الوزن

4: الدرجة

7.8% المساهمة

1	الصفيرة في الأنظمة الحيوية غير المرقعة استغلال الثغرات	عالية	حرج	إلزامية مع تصنيف الأصول حسب الأهمية وربط... برنامج إدارة التصحيحات الأمنية بدورة شهرية تطبيق	مركز العمليات الأمنية SOC مدير
2	على الحسابات ذات الصلاحيات العليا هجمات التصيد الاحتيالي المستهدفة	عالية	حرج	تفعيل المصادقة متعددة العوامل لجميع الحسابات... نشر بوابة تصفية البريد الإلكتروني المتقدمة مع	وحدة إدارة الهوية والوصول رئيس
3	الفدية الناتجة عن ضعف التجزئة الشبكية هجمات برمجيات	متوسطة	حرج	وعزل الأنظمة الحيوية مع اختبار سيناريوهات ال... تجزئة شبكية صارمة (Micro-segmentation) تنفيذ	CISO
4	ثالث لا يمثل لاشتراطات NCA DCC اختراق البيانات عبر طرف	متوسطة	عالي	موثق قبل منح الوصول وإدراج بنود الأمن السيبراني... إلزام جميع الموردين بتقديم تقرير تقييم أمني	حوكمة الأمن السيبراني مسؤول
5	بسبب غياب سجلات SIEM موحدة انعدام الكشف المبكر عن الحوادث	عالية	عالي	قواعد تنبيه موثقة مرتبطة بإجراءات الاستجابة... السجلات في منصة SIEM مركزية وتعريف توحيد مصادر	مركز العمليات الأمنية SOC مدير
6	من الكوارث عند وقوع حوادث كبرى قصور في استمرارية الأعمال والتعافي	متوسطة	عالي	سنوي يشمل سيناريوهات برمجيات الفدية... التعافي من الكوارث واختبارها بتمرين محاكاة توثيق خطة	CISO
7	مخاطر الموارد والطاقات	متوسط	عال	وطاقات تشغيلية للأمن السيبراني — المالك: CISO تخصيص موارد	CISO

نموذج الحوكمة والمسؤوليات

اللجنة التوجيهية للأمن السيبراني	اعتماد استراتيجية الأمن السيبراني والإشراف على تنفيذها: نطاق المسؤولية
مسألة عن التوجه الاستراتيجي واعتماد السياسات والميزانيات: المساءلة	ترفع تقاريرها إلى الإدارة العليا ومجلس الإدارة: التقارير / التصعيد
	NCA ECC / NCA DCC: الإطار المرتبط
رئيس الأمن السيبراني CISO	قيادة برنامج الأمن السيبراني وإدارة المخاطر السيبرانية: نطاق المسؤولية
مسألة عن تنفيذ الاستراتيجية والامتثال لـ NCA ECC و NCA DCC: المساءلة	يرفع التقارير إلى اللجنة التوجيهية والإدارة العليا: التقارير / التصعيد
	NCA ECC / NCA DCC: الإطار المرتبط
مدير حوكمة الأمن السيبراني	إدارة السياسات والمعايير ومتابعة الامتثال التنظيمي: نطاق المسؤولية
مسألة عن تطوير وتحديث سياسات الأمن السيبراني: المساءلة	يرفع التقارير إلى CISO: التقارير / التصعيد
	NCA ECC: الإطار المرتبط
مدير مركز العمليات الأمنية SOC	إدارة SOC والمراقبة المستمرة للتهديدات وتنفيذ SIEM: نطاق المسؤولية
مسألة عن كشف الحوادث الأمنية وزمن الاستجابة الأولية: المساءلة	يرفع التقارير إلى CISO ويصعد الحوادث الحرجة فوراً: التقارير / التصعيد
	NCA ECC: الإطار المرتبط
مدير حماية البيانات	إدارة DLP والتشفير وتصنيف البيانات وحمايتها: نطاق المسؤولية
مسألة عن تطبيق ضوابط حماية البيانات الحساسة: المساءلة	يرفع التقارير إلى CISO ويصعد حوادث تسرب البيانات: التقارير / التصعيد
	NCA DCC: الإطار المرتبط
مدير إدارة الهوية والوصول IAM/PAM	إدارة الهويات والصلاحيات وتنفيذ MFA للوصول المميز: نطاق المسؤولية
مسألة عن منع الوصول غير المصرح وإدارة الحسابات المميزة: المساءلة	يرفع التقارير إلى CISO: التقارير / التصعيد
	NCA ECC: الإطار المرتبط
مدير الاستجابة للحوادث CSIRT	قيادة فريق CSIRT وتنفيذ خطة الاستجابة للحوادث: نطاق المسؤولية
مسألة عن احتواء الحوادث وإدارتها حتى الإغلاق: المساءلة	يرفع التقارير إلى CISO ويصعد الحوادث ذات الأثر العالي: التقارير / التصعيد
	NCA ECC: الإطار المرتبط
مدير إدارة الثغرات	إدارة برنامج إدارة الثغرات وفحصها ومعالجتها وفق SLA: نطاق المسؤولية
مسألة عن معالجة الثغرات الحرجة خلال SLA المحدد: المساءلة	يرفع التقارير إلى CISO: التقارير / التصعيد
	NCA ECC: الإطار المرتبط

مدير استمرارية الأعمال / التعافي
إدارة استمرارية الأعمال والتعافي من الكوارث السيبرانية: نطاق المسؤولية
مسائل عن تنفيذ خطط BCP / DRP السيبرانية واختبارها: المساءلة
يرفع التقارير إلى CISO والإدارة العليا: التقارير / التصعيد
الإطار المرتبط: NCA ECC

مكتب إدارة المشاريع PMO
متابعة تنفيذ خارطة الطريق والمبادرات السيبرانية: نطاق المسؤولية
مسائل عن تتبع الإنجاز والمخاطر والتصعيد: المساءلة
يرفع التقارير إلى CISO واللجنة التوجيهية: التقارير / التصعيد
الإطار المرتبط: NCA ECC / NCA DCC

الإدارة العليا
الإشراف التنفيذي ورفع المخاطر السيبرانية إلى مجلس الإدارة: نطاق المسؤولية
مسألة عن دعم الموارد واتخاذ القرارات الاستراتيجية: المساءلة
ترفع التقارير إلى مجلس الإدارة: التقارير / التصعيد
الإطار المرتبط: NCA ECC / NCA DCC

مصفوفة تتبع الأطر المرجعية

NCA DCC (Data Cybersecurity Controls)
NCA DCC (Data Cybersecurity Controls)
الفجوة مجال القدرة الإطار المرجعي
NCA DCC (Data Cybersecurity Controls)
تصنيف البيانات: مجال القدرة
ضعف تصنيف وجرّد البيانات الحساسة: الفجوة
NCA DCC (Data Cybersecurity Controls)
التشفير: مجال القدرة
ضعف ضوابط التشفير وإدارة المفاتيح: الفجوة
NCA DCC (Data Cybersecurity Controls)
منع تسرب البيانات / DLP: مجال القدرة
ضعف ضوابط منع تسرب البيانات: الفجوة
NCA DCC (Data Cybersecurity Controls)
معالجة البيانات الحساسة: مجال القدرة
ضعف معالجة البيانات الحساسة: الفجوة
NCA DCC (Data Cybersecurity Controls)
حماية البيانات: مجال القدرة
ضعف حماية البيانات أثناء النقل والتخزين: الفجوة
NCA DCC (Data Cybersecurity Controls)
NCA DCC (Data Cybersecurity Controls)
المخاطر المؤشر المبادرة الإطار
NCA DCC (Data Cybersecurity Controls)
تنفيذ تصنيف البيانات / تصنيف البيانات الحساسة: المبادرة
نسبة تصنيف البيانات الحساسة: المؤشر
اختراق البيانات أو سوء تصنيف البيانات الحساسة: المخاطر
NCA DCC (Data Cybersecurity Controls)
تطبيق ضوابط التشفير: المبادرة
نسبة الامتثال لسياسات التشفير: المؤشر
تسرب البيانات أثناء النقل أو التخزين: المخاطر
NCA DCC (Data Cybersecurity Controls)
تطبيق DLP / منع تسرب البيانات: المبادرة
عدد حوادث تسرب البيانات أو مؤشرات منع التسرب: المؤشر
فقدان البيانات الحساسة: المخاطر
NCA DCC (Data Cybersecurity Controls)
معالجة البيانات الحساسة وفق الضوابط: المبادرة
نسبة الأصول الحساسة المصنفة أو المحمية: المؤشر
إفشاء غير مصرح للبيانات الحساسة: المخاطر
NCA DCC (Data Cybersecurity Controls)
حماية البيانات أثناء النقل والتخزين: المبادرة
نسبة الأصول المشفرة أو المحمية: المؤشر

اختراق البيانات أو ضعف حماية البيانات: المخاطر

NCA ECC (Essential Cybersecurity Controls)

NCA ECC (Essential Cybersecurity Controls)

الفجوة | مجال القدرة | الإطار المرجعي

NCA ECC (Essential Cybersecurity Controls)

حوكمة الأمن السيبراني: مجال القدرة

غياب هيكل حوكمة الأمن السيبراني / CISO: الفجوة

NCA ECC (Essential Cybersecurity Controls)

إدارة الهوية والوصول: مجال القدرة

ضعف إدارة الهوية والوصول MFA / PAM / IAM: الفجوة

NCA ECC (Essential Cybersecurity Controls)

الرصد الأمني (SIEM / SOC): مجال القدرة

غياب مركز العمليات الأمنية SIEM / SOC: الفجوة

NCA ECC (Essential Cybersecurity Controls)

الاستجابة للحوادث: مجال القدرة

غياب فريق الاستجابة للحوادث CSIRT وخطة مؤتمنة: الفجوة

NCA ECC (Essential Cybersecurity Controls)

إدارة الثغرات: مجال القدرة

قصور إدارة الثغرات الأمنية ومنع فقدان البيانات DLP: الفجوة

NCA ECC (Essential Cybersecurity Controls)

NCA ECC (Essential Cybersecurity Controls)

المخاطر | المؤشر | المبادرة | الإطار

NCA ECC (Essential Cybersecurity Controls)

تأسيس إدارة الأمن السيبراني وتشكيل لجنة حوكمة الأمن السيبراني: المبادرة

نسبة اكتمال الهيكل التنظيمي والسياسات المعتمدة: المؤشر

ضعف الحوكمة أو غياب المساءلة السيبرانية: المخاطر

NCA ECC (Essential Cybersecurity Controls)

تطبيق IAM/PAM/MFA: المبادرة

نسبة تطبيق المصادقة متعددة العوامل MFA للوصول المميز: المؤشر

اختراق أنظمة التحكم في الوصول والهوية: المخاطر

NCA ECC (Essential Cybersecurity Controls)

تأسيس مركز العمليات الأمنية SOC وتنشيط SIEM: المبادرة

متوسط زمن كشف الحوادث الأمنية الحرجة: المؤشر

فشل آليات الكشف المبكر للتهديدات المتقدمة: المخاطر

NCA ECC (Essential Cybersecurity Controls)

تأسيس فريق CSIRT وتطوير خطة الاستجابة للحوادث: المبادرة

متوسط زمن الاستجابة للحوادث الحرجة: المؤشر

تأخر احتواء الحوادث أو ضعف الاستجابة للحوادث: المخاطر

NCA ECC (Essential Cybersecurity Controls)

تنفيذ برنامج إدارة الثغرات الأمنية وفحص الثغرات: المبادرة

نسبة الثغرات الحرجة المعالجة خلال SLA المحدد: المؤشر

استغلال الثغرات الحرجة في الأنظمة الحكومية: المخاطر

الملاحق

الملحق أ — الأطر المرجعية

الأطر المرجعية المستخدمة في إعداد هذه الوثيقة:

- ECC: NCA ECC (Essential Cybersecurity Controls)
- DCC: NCA DCC (Data Cybersecurity Controls)

الملحق ب — قاموس المصطلحات

تعريفات المصطلحات والاختصارات المستخدمة في هذه الوثيقة:

- (NCA) الضوابط الأساسية للأمن السيبراني: ECC
- (NCA) ضوابط الأمن السيبراني للبيانات: DCC
- المصادقة متعددة العوامل: MFA
- الشبكة الافتراضية الخاصة: VPN
- إدارة الهوية والوصول: IAM
- إدارة الوصول المميز: PAM
- مركز العمليات الأمنية: SOC
- إدارة المعلومات والأحداث الأمنية: SIEM
- فريق الاستجابة لحوادث الأمن السيبراني: CSIRT
- منع تسرب البيانات: DLP
- مؤشر المخاطر الرئيسي: KRI
- تصنيف البيانات: Data Classification
- كشف التهديدات والاستجابة في النقاط الطرفية: EDR
- مؤشر الأداء الرئيسي: KPI